

Project ATLAS

Post-Incident Review (PIR) & Root Cause Analysis

Incident ID:	2	Classification:	True Positive — Compromised Account
Severity:	High	Date of Incident:	3–4 July 2026
Analyst:	Ivan Yamoah Baoakye	PIR Date:	5 July 2026
Status:	Closed	Environment:	VANPASSSC200 / law-soc-atlas

1. Incident Summary

On 3 July 2026 at 23:14 local time, Microsoft Entra ID Protection detected the first of five anonymous IP address sign-in events originating from Tor exit nodes in Germany and Sweden. The affected accounts were the tenant administrator and a test account (soc-tor-test@VANPASSSC200.onmicrosoft.com). Microsoft Defender XDR auto-correlated 8 identity risk alerts into Incident ID 2, generating a High-severity 'Initial access incident involving one user.' AI-generated technique profile identified 'token theft and token replay for unauthorized access.' All sign-ins succeeded — no MFA or Conditional Access policy was in place to block or challenge sign-ins from anonymous IP addresses.

2. Timeline of Events

Time (Local)	Event	Source
3 Jul 23:14:11	First Anonymous IP address detection	Entra ID Protection
3 Jul 23:15:16	Anomalous Token detection fires	Entra ID Protection
3 Jul 23:17:22	Incident ID 2 created	Microsoft Defender XDR
3 Jul 23:17–23:18	Three additional Anonymous IP + Anomalous Token alerts	Entra ID Protection
4 Jul 00:07:04–08	Two final Anonymous IP alerts (Germany Tor exit)	Entra ID Protection
5 Jul 10:56	Analyst opened incident, reviewed alert timeline	SOC analyst
5 Jul 10:56	Classified: True positive — Compromised account	SOC analyst
5 Jul 10:57	DESKTOP-TRF9U79 isolated via host-based firewall	SOC analyst
5 Jul 11:00	SOC Tor Test user confirmed compromised	SOC analyst
5 Jul 11:37	Conditional Access policy created (Report-only)	SOC analyst

Detection-to-triage gap: ~35 hours (simulated environment, no on-call coverage). **Triage-to-containment:** ~4 minutes.

3. Root Cause Analysis

3.1 Immediate Cause

A valid account authenticated successfully via Tor exit-node IP addresses. Authentication succeeded because: (1) no MFA was enforced on the account; (2) no Conditional Access policy existed to block or challenge sign-ins from

high-risk IPs or anonymous proxies; (3) Security Defaults had been disabled on the tenant (required for Conditional Access testing), removing the baseline MFA requirement.

3.2 Contributing Factors

- **CF-1 — No risk-based Conditional Access policy:** Entra ID Protection detected the anonymous IP correctly but had no enforcement mechanism. Detection without enforcement is visibility without defence.
- **CF-2 — Endpoint telemetry pipeline failure (AMA):** Both SecurityEvent and Sysmon Event tables contained 0 records. T1110.001 (brute force) and T1059.001/T1027 (encoded PowerShell) generated no Sentinel alerts — endpoint-layer detection completely blind.
- **CF-3 — No phishing-resistant MFA:** Attack Simulation Training achieved 100% compromise (1/1 click, 1/1 credential submission). FIDO2 or Authenticator number matching would have prevented this.
- **CF-4 — No Named Locations configured:** No trusted IP ranges defined, reducing ability to scope Conditional Access policies tightly.

4. Impact Assessment

Impact Area	Assessment
Data exfiltration	None — test tenant, no sensitive data
Lateral movement	None confirmed — limited to cloud identity layer
Persistence	None — no OAuth tokens or app registrations created
Availability	None — no service disruption
Detection coverage	HIGH IMPACT — endpoint telemetry gap leaves T1110.001 and T1059.001 blind
Identity risk	Medium — successful Tor sign-in to test account; admin account also flagged

5. Detection Effectiveness Review

Detection Rule	Expected	Fired?	Reason
ATLAS 4.1 — Brute force spike	Yes	■ No	SecurityEvent = 0 (AMA failure)
ATLAS 4.2 — Encoded PowerShell	Yes	■ No	Sysmon Event = 0 (AMA failure)
OOB: Multi-auth failures + success	Yes	■ No	SecurityEvent = 0 (AMA failure)
Entra ID Protection: Anonymous IP	Yes	■ Yes	Cloud identity telemetry (independent of AMA)
Entra ID Protection: Anomalous Token	Possible	■ Yes	Cloud identity telemetry (independent of AMA)

Coverage: 2/5 rules fired (40%) — endpoint layer completely blind.

6. Recommendations (Priority Order)

P1 — Critical	Remediate AMA agent on DESKTOP-TRF9U79. Validate both DCRs deliver data to SecurityEvent and Event tables. Without this, ATLAS rules 4.1 and 4.2 are non-functional.
P2 — High	Flip Conditional Access policy from Report-only to On after validating P1 and confirming no false-positive lockout risk.

P3 — High	Enforce phishing-resistant MFA (Authenticator number matching or FIDO2). 100% phishing compromise rate confirms this is not optional.
P4 — Medium	Deploy Microsoft Defender for Endpoint to replace Sysmon/AMA. MDE provides pre-parsed, always-on telemetry that does not depend on manual AMA pipeline configuration.
P5 — Medium	Implement SOAR playbook (Sentinel Logic App) to auto-notify on High-risk Entra ID Protection sign-ins and auto-disable account pending analyst review.

7. Lessons Learned

What went well:

- Cloud identity detection was fast and accurate — Entra ID Protection fired within seconds of the Tor sign-in
- Incident auto-correlation saved triage time — 8 alerts grouped into 1 actionable incident automatically
- Proactive threat hunting surfaced the telemetry gap — without hunting, the AMA failure would have remained invisible
- Manual containment was effective — endpoint isolation without EDR demonstrates process depth

What to improve:

- ■ Never rely on a single telemetry pipeline — AMA failure left 3 of 5 techniques undetected
- ■ Validate detection rules before attack simulation — run SecurityEvent | take 10 at session start
- ■ Report-only Conditional Access is not containment — deploy → review 2–4 weeks → flip to On